VAPT Engagement Letter & Scope Template

As of 12 October 2026

Use this as the master template for every VAPT (or related security assessment) engagement. Fill the bracketed fields per client, get it signed by an authorized representative on the client side, and keep the countersigned copy before any testing begins. No exceptions — no "just test this quickly" without a signed copy on file.

---

1. Parties

Service Provider: [Your Business / Proprietorship Name] Udyam Reg. No.: [fill in] Represented by: Sujal Kadam, Proprietor Address: [fill in]

Client: [Client Legal Name] Represented by: [Name, Designation] ("Authorized Representative") Address: [fill in]

This Engagement Letter ("Letter") sets out the terms under which Service Provider will perform the security assessment(s) described in the attached Scope Template for Client.

---

2. Purpose and Objectives

Service Provider will conduct a [Web Application VAPT / Network VAPT / Secure Configuration Review / Phishing Simulation — select and list all that apply] engagement to identify security vulnerabilities, misconfigurations, and weaknesses in the systems defined in the Scope Template, and to provide actionable remediation guidance.

This engagement is **authorized penetration testing performed with the Client's explicit written consent**. Nothing in this Letter authorizes testing of any system, network, or asset not explicitly listed in the Scope Template.

---

3. Authorization (Rules of Engagement)

By signing this Letter, the Authorized Representative confirms they have the legal authority to authorize security testing against the assets listed in the Scope Template, including assets that may be hosted by third parties (cloud providers, ISPs, SaaS vendors) — and that any required third-party consent has been separately obtained by Client.

- Testing will be conducted strictly within the dates, times, and methods defined in the Scope Template.

- Service Provider will not access, exfiltrate, modify, or delete Client data beyond what is strictly necessary to demonstrate a vulnerability (proof-of-concept only).
- Service Provider will immediately halt testing and notify Client if evidence of a live, unrelated compromise (another attacker already in the environment) is found.
- Client designates an Emergency Contact (Section 9) who can be reached throughout the testing window to pause or redirect testing if needed.

---

4. Methodology

Testing will follow industry-standard methodology appropriate to the engagement type:

- Web VAPT: OWASP Web Security Testing Guide (WSTG) + OWASP Top 10
- Network VAPT: PTES (Penetration Testing Execution Standard)
- Secure Configuration Review: CIS Benchmarks for the relevant platform
- Phishing Simulation: Agreed pretext scenario(s), no data beyond click/report metrics is retained from individual employees without Client consent

Testing combines automated tooling with manual verification and exploitation of identified issues to confirm real-world impact and eliminate false positives.

---

5. Deliverables

- Draft report for Client review: findings, severity (CVSS v3.1 scored), proof-of-concept evidence, remediation steps
- Executive summary (non-technical, for leadership)
- Final report incorporating Client feedback
- One (1) complimentary retest within 30 days of final report delivery, scoped to previously identified findings only

---

6. Timeline

Milestone	Date
Engagement start	[date]
Testing window	[start] – [end]
Draft report delivery	[date]
Client feedback window	[date] – [date]

Milestone	Date
Final report delivery	[date]
Retest window (if applicable)	within 30 days of final report

---

7. Confidentiality and Data Handling

- All findings, credentials, and data accessed during testing are treated as strictly confidential.
- Report and all engagement artifacts are shared only with the Client's designated contacts.
- Any Client data incidentally accessed during testing is not retained beyond what's needed for report evidence, and is securely deleted within [30/60] days of final report delivery.
- Service Provider will not disclose the existence or outcome of this engagement publicly without Client's written consent (case studies, portfolio use, etc. require separate written permission).

---

8. Limitation of Liability

- Testing is performed using generally accepted industry tools and techniques; while reasonable care is taken, Service Provider does not guarantee zero service disruption — Client acknowledges inherent risk in live-system testing (recommend a maintenance window / staging environment where critical systems are involved).
- Service Provider's liability under this engagement is limited to the fees paid for this engagement.
- This report reflects the security posture at the time of testing only; it is not a guarantee against future compromise.

---

9. Emergency Contacts

Role	Name	Phone	Email
Client Emergency Contact	[name]	[phone]	[email]
Service Provider Contact	Sujal Kadam	[phone]	[email]

---

10. Commercial Terms

- Fee: INR [amount], per the Service Menu — 50% advance, 50% on final report delivery
- Additional retests beyond the included one: INR [amount] per retest
- Scope changes mid-engagement require a signed addendum and may affect timeline/fee

---

11. Signatures

For Service Provider: Name: Sujal Kadam Signature: _____ Date: _____

For Client: Name: [Authorized Representative] Designation: [title] Signature: _____ Date: _____

Scope Template (attach to every Engagement Letter)

A. In-Scope Assets

Asset Type	Identifier (URL / IP range / hostname)	Environment (Prod/Staging)	Notes
[Web app]	[URL]	[ ]	[auth roles to test]
[Network]	[IP range/CIDR]	[ ]	[internal/external]
[ ]	[ ]	[ ]	[ ]

B. Explicitly Out-of-Scope

- [List any systems, subdomains, IP ranges, third-party integrations explicitly excluded]
- Denial-of-Service (DoS/DDoS) testing — excluded unless separately agreed in writing
- Physical security / social engineering beyond agreed phishing scenario — excluded unless separately agreed
- Any system not explicitly listed in Section A above

C. Testing Window

- Permitted days/hours: [e.g. weekdays 10:00–18:00 IST, or 24/7 if agreed]
- Blackout dates (no testing): [e.g. month-end billing cycle, product launch week]

D. Testing Source

- Source IP(s) testing will originate from: [static IP(s) if Client needs to whitelist for monitoring visibility, or note "dynamic — Client SOC to expect alerts during testing window"]

E. Credentials Provided (if any, for authenticated testing)

Role/Account	Username	Access Level	Provided By	Date
[ ]	[ ]	[ ]	[ ]	[ ]

F. Special Instructions

- [e.g. "Do not test the payment gateway integration — third-party PCI scope"]
- [e.g. "Pause testing and call Emergency Contact immediately if any production alert fires"]

G. Sign-off

This Scope Template is incorporated into and governed by the Engagement Letter above. Any change to this scope requires a signed addendum before testing proceeds under the new scope.

Client Authorized Representative: _____ Date: _____ Service Provider: _____ Date: _____